

Authentication Flow Documentation

Overview

This application implements secure authentication using AWS Cognito with the OAuth 2.0 Authorization Code Flow. User sessions are managed using JWT tokens stored in secure HTTP cookies.

1. Sign Up Flow

Flow Sequence:

User → Cognito Hosted UI → OAuth Code → Callback → User Creation → Session

Step-by-Step Process:

1. Initial Trigger:

- User accesses a protected route.
- Middleware detects missing `access_token`.
- Redirects to Cognito Hosted UI.

2. Cognito Hosted UI:

URL: `{COGNITO_DOMAIN}/login`

Parameters: `client_id`, `response_type`, `scope`, `redirect_uri`, `state`.

3. OAuth Callback:

File: `src/pages/api/auth/callback.ts`

- Receive Authorization Code.
- Exchange Code for Tokens.
- Extract User Information.
- Check/Create User.
- Create Session Cookies.
- Redirect to original URL.

2. Sign In Flow

Similar to Sign Up flow but skips user creation if the user already exists.

3. Token Management

Tokens: Access Token (1h), ID Token (1h), Refresh Token (30d).

JWT decoded to extract user identity and permissions.

4. Token Refresh Flow

Middleware verifies tokens. If expired, refreshes using `refresh_token`.

5. Logout Flow

Clears cookies and redirects to Cognito logout endpoint.

6. Session Management

Loads user data from cookies or JWT. Supports cross-tab sync.

7. Inactivity Timeout

Triggers warning after 25 minutes, logout after 30 minutes of inactivity.

8. Route Protection

Protected routes checked via middleware. Invalid tokens trigger refresh or redirect.

9. Security Features

Includes cookie security, JWT validation, state validation, and environment checks.

10. Error Handling

Handles token failures, missing codes, and redirects user to error pages.

11. Key Files Reference

Lists main source files and their purposes.

12. Environment Variables

Defines required environment variables for Cognito and session management.

13. Features Summary

- ✓ Secure OAuth 2.0 with Cognito
- ✓ Token refresh
- ✓ Session management
- ✓ Logout
- ✓ Route protection
- ✓ XSS/CSRF protection